Individual Contribution Statement - Duong Tran Quoc Khanh

Course	Introduction to Information Security 2026-2027
Class / Group	N05 / Group 05
Name	Duong Tran Quoc Khanh
Student ID	523H0040
Primary responsibility	Authentication, authorization and implementation
Project	Design, Implement, and Audit Secure Access Control - University Records System (UniRecords)

1. Tasks completed

- **Authentication:** login with Argon2id password hashing (`source/app/security.py`), one generic error message, a dummy hash for unknown users, lockout after five failures, rejection of disabled accounts, and server-side sessions that are revoked at logout (`source/app/routes/auth.py`).
- **Session and CSRF protection:** a random 256-bit token renewed at every login and stored only as SHA-256, HttpOnly and SameSite=Strict cookies, idle and absolute timeouts, and a per-session CSRF token on every POST.
- **Authorization:** the default-deny decorators and the start-up check `verify_all_endpoints_declared()`, plus record-level checks against IDOR (`can_access_student`, `can_access_course`) in `source/app/authz.py`.
- **Application features:** student records, enrollments, administration of users and roles, the auditor views, student self-registration, the class catalog (join, leave, take a class), class creation with at most one lecturer and 30 students, class locking and starting (after the start the lecturer cannot leave and may remove students), and grade entry with four weighted components.
- **Account self-service:** password change for every role, renaming for students and lecturers, and the administrator-approved forgot-password workflow (`source/app/routes/account.py`).
- **User interface:** the responsive UniRecords design (`static/style.css`, `static/app.js`, the templates), with no inline script or style, so that the strict CSP holds.
- **Report:** wrote Chapters 2 and 5.
- **Demo video:** segment 2 (authentication and one authorized operation).

2. Repository commits

My commits are recorded in the group repository: **https://github.com/duongtranquockhanhwork/Project-for-user-roles** (GitHub account `duongtranquockhanhwork`, commit author **Duong Tran Quoc Khanh**). They can be listed with `git log --author="Duong Tran Quoc Khanh" --date=short` or on the repository's *Commits* page.

As the member responsible for the implementation, I created the repository and imported the first versions of the project (source code, database scripts, tests and documentation) in these commits:

Commit	Date	Message
f76f988	2026-11-10	Initial commit
40e16fb	2026-11-10	update code

Commit	Date	Message
6c8d96c	2026-11-10	Update project files

Later commits are listed in the repository history.

3. Technical decisions made

- **Server-side sessions instead of signed client cookies.** Logout and account disabling then take effect immediately, and a database leak does not reveal usable tokens.
- **A start-up check that refuses to run if any route has no access rule.** A forgotten authorization check cannot silently expose an endpoint.
- **Confirmation messages from a fixed server-side list** (`?notice=<code>`), so that no request text is ever reflected in a page.
- **The temporary password is generated when the requester reveals it, not when the administrator approves.** The password is never stored and never seen by the administrator.
- **Self-service class actions act only on the user's own enrollment or teaching assignment.** Arranging other people remains a registrar duty.

4. Problems solved

- **The CSP blocked the progress bars** of the class seat counters, because inline `style` attributes are forbidden. I replaced them with width classes in the stylesheet, so the policy did not need to be relaxed.
- **Forced password change after a reset** had to leave only the account page and logout reachable. I implemented this centrally in the request hook rather than in every route.
- **The registration form reported only the first validation error.** I changed it to collect every problem (format, length, mismatching confirmation, username in the password, taken username) and show them together.
- **Wrong current passwords on the change form** could be used to guess a password. I made these failures count towards the same lockout as failed logins.

5. Approximate hours worked

[to be filled] hours in total (week 1: [ ] h, week 2: [ ] h, week 3: [ ] h).

6. Contributions of the other members

- **Trieu Ngoc Van Anh** produced the threat model, the DFD, the security requirements, the access-control matrix and policy, and the remaining-risk review, and wrote report Chapters 1, 3, 4 and 8.
- **Nguyen Vo Thanh Tu** built the database security layer (grants, triggers, generated grade totals, capacity guard, hash-chained audit log), wrote the automated test suite and the evidence capture, and wrote report Chapters 6 and 7 and the appendices.

7. Review of the complete submission

I reviewed the complete submission (source code, database scripts, tests, evidence, report and demo video) and agree with its content.

Date: ____ / ____ / 2026

Signature: _____

Duong Tran Quoc Khanh (523H0040)